

Blackthorn

Security Review For Aave Labs

Collaborative Audit Prepared For: **Aave Labs**

Lead Security Expert(s): **0x52**
bughuntoor
mstpr-brainbot
pkqs90

Date Audited: **February 10 - February 24, 2026**

Introduction

Aave V4 introduces a new Hub and Spoke architecture. This architecture introduces several new design paradigms to Aave, each with their own set of benefits.

Capital is no longer fragmented across markets on the same chain. Instead, all liquidity flows through Liquidity Hubs, which increases utilization and unlocks better rates for both suppliers and borrowers. Governance also becomes lighter. New Spokes can be added or upgraded without disrupting the rest of the system.

To price risk more accurately, V4 also introduces Risk Premiums. This system ties borrowing rates to the quality of the collateral provided. Users with 'safer' collateral receive better rates, which creates a more efficient market where users' borrow rates better reflect actual risk.

Protocol Contacts

- Adam Schoeman (CISO, Aave Labs)
- Emilio Frangella (SVP of Engineering, Aave Labs)
- Stani Kulechov (CEO, Aave Labs)

Scope

Repository: `aave/aave-v4`

Audited Commit: [c3b92877ec49c791e7eaaf77afe73eabd9bb7b1e](#)

Final Commit: [1486b5165b0ded213c5b6c1b52d046e3f221e5a4](#)

Files:

- `src/access/AccessManagerEnumerable.sol`
- `src/access/interfaces/IAccessManagerEnumerable.sol`
- `src/hub/AssetInterestRateStrategy.sol`
- `src/hub/HubConfigurator.sol`

- src/hub/Hub.sol
- src/hub/interfaces/IAssetInterestRateStrategy.sol
- src/hub/interfaces/IBasicInterestRateStrategy.sol
- src/hub/interfaces/IHubBase.sol
- src/hub/interfaces/IHubConfigurator.sol
- src/hub/interfaces/IHub.sol
- src/hub/libraries/AssetLogic.sol
- src/hub/libraries/Premium.sol
- src/hub/libraries/SharesMath.sol
- src/interfaces/IExtSload.sol
- src/interfaces/IIntentConsumer.sol
- src/interfaces/IMulticall.sol
- src/interfaces/INoncesKeyed.sol
- src/interfaces/IRescuable.sol
- src/libraries/math/MathUtils.sol
- src/libraries/math/PercentageMath.sol
- src/libraries/math/WadRayMath.sol
- src/libraries/types/Roles.sol
- src/misc/UnitPriceFeed.sol
- src/position-manager/GatewayBase.sol
- src/position-manager/interfaces/IGatewayBase.sol
- src/position-manager/interfaces/INativeTokenGateway.sol
- src/position-manager/interfaces/INativeWrapper.sol
- src/position-manager/interfaces/ISignatureGateway.sol

- src/position-manager/libraries/EIP712Hash.sol
- src/position-manager/NativeTokenGateway.sol
- src/position-manager/SignatureGateway.sol
- src/spoke/AaveOracle.sol
- src/spoke/instances/SpokeInstance.sol
- src/spoke/instances/TokenizationSpokeInstance.sol
- src/spoke/interfaces/IAaveOracle.sol
- src/spoke/interfaces/IPriceOracle.sol
- src/spoke/interfaces/ISpokeBase.sol
- src/spoke/interfaces/ISpokeConfigurator.sol
- src/spoke/interfaces/ISpoke.sol
- src/spoke/interfaces/ITokenizationSpoke.sol
- src/spoke/interfaces/ITreasurySpoke.sol
- src/spoke/libraries/EIP712Hash.sol
- src/spoke/libraries/KeyValueList.sol
- src/spoke/libraries/LiquidationLogic.sol
- src/spoke/libraries/PositionStatusMap.sol
- src/spoke/libraries/ReserveFlagsMap.sol
- src/spoke/libraries/SpokeUtils.sol
- src/spoke/libraries/UserPositionDebt.sol
- src/spoke/libraries/UserPositionUtils.sol
- src/spoke/SpokeConfigurator.sol
- src/spoke/Spoke.sol
- src/spoke/SpokeStorage.sol

- `src/spoke/TokenizationSpoke.sol`
- `src/spoke/TreasurySpoke.sol`
- `src/utils/Multicall.sol`
- `src/utils/NoncesKeyed.sol`
- `src/utils/Rescuable.sol`

Final Commit Hash: [1486b5165b0ded213c5b6c1b52d046e3f221e5a4](#)

Findings

Each issue has an assigned severity:

- High issues are directly exploitable security vulnerabilities that need to be fixed.
- Medium issues are security vulnerabilities that may not be directly exploitable or may require certain conditions in order to be exploited. All major issues should be addressed.
- Low/Info issues are non-exploitable, informational findings that do not pose a security risk or impact the system's integrity. These issues are typically cosmetic or related to compliance requirements, and are not considered a priority for remediation.

Issues Found

High	Medium	Low/Info
0	0	0

Issues Not Fixed and Not Acknowledged

High	Medium	Low/Info
0	0	0

Security Experts Dedicated to This Review

@0x52

A stylized, cursive handwritten signature in white ink, featuring a large, sweeping 'X' shape.

@bughuntoor

A cursive handwritten signature in white ink, with the word 'Dead' visible at the beginning.

@mstpr-brainbot

A cursive handwritten signature in white ink, with the word 'Tapir' visible at the beginning.

@pkqs90

A cursive handwritten signature in white ink, with the letters 'Pkqs' visible at the beginning.

No issues identified during the audit

The review covered the full set of contracts comprising the protocol's core, namely:

- the Hub and its configurator, asset interest rate strategy, and supporting libraries (AssetLogic, Premium, SharesMath)
- the Spoke and its configurator, including the tokenization and treasury spoke variants, and the libraries governing liquidation, user position accounting, reserve flags, position status tracking, and EIP-712 signing (LiquidationLogic, UserPositionUUtils, UserPositionDebt, PositionStatusMap, ReserveFlagsMap, KeyValueList, SpokeUtils)
- the position manager layer – NativeTokenGateway, SignatureGateway, and the shared gateway base
- the access control stack (AccessManagerEnumerable, Roles)
- the supporting math libraries (WadRayMath, PercentageMath, MathUtils)
- the oracle layer (AaveOracle, UnitPriceFeed)
- the protocol utilities (Multicall, NoncesKeyed, Rescuable)

Particular attention was paid to liquidation accounting and the share-based debt and supply math, the boundary between Hub and Spoke instances, signing surfaces exposed by SignatureGateway, the configuration paths gated by the access manager, and the storage layout's upgrade-safety properties.

The commit has been signed off on by the Blackthorn team.

Disclaimers

Blackthorn does not provide guarantees nor warranties relating to the security of the project.

Usage of all smart contract software is at the respective users' sole risk and is the users' responsibility.